AI Governance and Risk Assessment

A Simulated Case Study of Generative AI Risks in a SaaS Company

Author	Nancy Okereke
Project type	AI Governance / GRC
Industry	Software as a Service (SaaS)
Organisation size	100 employees (fictional)
Location	United States
Assessment type	Simulated organisational risk assessment
Frameworks	NIST AI RMF 1.0, NIST CSF 2.0

Simulation notice. This is a simulated assessment based on fictional organisational details and assumed control gaps. It is not an actual security audit and contains no verified findings.

Contents

1. Executive Summary

2. Organisation Background and Scope

3. Assessment Methodology

4. Assumptions and Existing Control Environment

5. AI Risk Register

6. Detailed Risk Assessment and Treatment

7. AI Acceptable-Use Policy: Recommended Key Requirements

8. Recommended AI Governance Structure

9. 90-Day AI Governance Roadmap

10. Residual Risk Assessment

11. Conclusion

12. Limitations

13. References

At a Glance

Item	Summary
Risks assessed	12 (11 High, 1 Moderate, 0 Critical)
Framework alignment	Every risk mapped to NIST AI RMF functions and NIST CSF 2.0 categories
Deliverables	Risk register, treatment plans, policy requirements, governance structure, 90-day roadmap, residual risk summary

1. Executive Summary

Generative AI tools can improve productivity across business functions, but their adoption introduces security, privacy, operational, legal and reputational risks.

This project assesses the risks associated with generative AI use within a fictional US-based SaaS company with approximately 100 employees. The company uses generative AI across marketing, customer support, human resources, software development and internal operations. Its AI adoption has developed faster than its governance processes.

The assessment identifies 12 risks, including sensitive data exposure, inaccurate AI-generated content, intellectual property concerns, unauthorised AI tools, overreliance on AI outputs, insecure AI-generated code, prompt injection, bias in HR use cases, regulatory non-compliance and the absence of AI-specific incident response.

It recommends establishing an AI governance structure, introducing an acceptable-use policy, maintaining an approved AI tools register, delivering employee awareness training, and implementing technical and human oversight controls. A 90-day roadmap helps the organisation address priority risks and establish a more controlled approach to AI adoption.

2. Organisation Background and Scope

The fictional organisation is a US-based SaaS company employing approximately 100 people. It provides cloud-based software products to business customers and has introduced generative AI tools to improve employee productivity.

Business functions using AI

Department	AI use cases
Marketing	Social media posts, email campaigns, blogs and advertising copy
Customer Support	Drafting customer responses and summarising support tickets
Human Resources	Drafting job descriptions and supporting recruitment activities
Software Development	Code generation, debugging and documentation
Operations	Internal documentation, research and meeting summaries

Objective

To identify and evaluate the risks associated with the company's use of generative AI and recommend governance measures to reduce those risks.

Scope

In scope: employee use of generative AI tools; handling of confidential and personal information; accuracy and reliability of AI-generated outputs; intellectual property and copyright considerations; AI tool approval and oversight; human accountability and employee awareness; fairness considerations in HR use cases; AI-specific incident handling.

Out of scope: penetration testing, source code security testing, vendor audits and a formal legal compliance review.

3. Assessment Methodology

The assessment follows a risk-based approach informed by the NIST AI Risk Management Framework.

1. Identify AI use cases across business functions.
2. Identify potential risks associated with each use case.
3. Evaluate likelihood and business impact.
4. Map risks and controls to NIST AI RMF and CSF 2.0.
5. Recommend controls and risk treatment measures.
6. Establish an implementation roadmap and monitoring approach.

Risk scoring

Each risk is scored on a five-point likelihood scale and a five-point impact scale. Risk score = Likelihood x Impact.

Score	Rating
1-4	Low
5-9	Moderate
10-16	High
17-25	Critical

Score	Likelihood	Impact
1	Rare	Insignificant
2	Unlikely	Minor
3	Possible	Moderate
4	Likely	Major
5	Almost certain	Severe

These thresholds are illustrative criteria developed for this case study, not a prescribed NIST scoring system.

Why no risk is rated Critical

A Critical rating (17-25) requires, for example, a likelihood of at least 4 combined with an impact of 5, or a likelihood of 5 with an impact of at least 4. In this scenario, no single event is both almost certain and severe. The highest-impact risks (R-006 and R-007) are rated as possible rather than likely because the scenario assumes some baseline engineering practices, such as peer review, are already in place. The clustering of High ratings reflects the real picture: many significant risks that need treatment, none yet at crisis level. Different assumptions would change the ratings.

Framework mapping approach

Each risk is mapped to the most relevant functions of the NIST AI RMF (Govern, Map, Measure, Manage) and categories of NIST CSF 2.0 (for example GV.PO for Policy, ID.AM for Asset Management, PR.DS for Data Security). The mappings are illustrative and show alignment of thinking; they are not a formal compliance mapping.

4. Assumptions and Existing Control Environment

The following conditions are assumed for the fictional organisation. They set the baseline and are not verified findings.

Control area	Scenario assumption
AI governance policy	No formal AI acceptable-use policy
Approved AI tools	No documented register of approved AI tools
Data protection	No confirmed technical safeguards preventing sensitive data from being entered into public AI tools
Employee awareness	No confirmed organisation-wide AI security training
Human oversight	No documented review requirements for AI-generated external content
Vendor oversight	No documented AI-specific third-party risk assessment process
Accountability	No clearly documented AI governance ownership structure
Software development	General peer code review exists, but there is no AI-specific guidance
HR processes	No documented review of AI-assisted recruitment for fairness
Incident response	A general incident response process exists but does not cover AI-specific incidents

5. AI Risk Register

ID	Risk	Departments	L	I	Score	Rating	NIST AI RMF	NIST CSF 2.0
R-001	Sensitive information exposure through AI tools	All	4	4	16	High	Govern, Map	PR.DS, PR.AT, GV.PO
R-002	Inaccurate or misleading AI-generated content	Marketing, Support	4	4	16	High	Measure, Manage	GV.PO, GV.RR
R-003	Copyright and intellectual property infringement	Marketing, Development	3	4	12	High	Govern, Map	GV.OC, GV.PO
R-004	Unauthorised or unapproved AI tool usage	All	4	4	16	High	Govern, Map	ID.AM, GV.PO
R-005	Overreliance on AI outputs without human verification	All	3	4	12	High	Govern, Manage	GV.RR, PR.AT
R-006	Exposure of customer information through AI integrations	Support, Operations	3	5	15	High	Map, Manage	PR.DS, GV.SC
R-007	Insecure AI-generated code entering production	Development	3	5	15	High	Measure, Manage	PR.PS, ID.RA
R-008	Third-party AI provider security and privacy weaknesses	All	3	4	12	High	Govern, Map	GV.SC, ID.RA
R-009	Prompt injection and data leakage through AI integrations	Support, Operations, Development	3	4	12	High	Map, Measure	PR.PS, DE.CM, ID.RA
R-010	Bias and discrimination in AI-assisted HR activities	HR	3	4	12	High	Map, Measure, Manage	GV.OC, ID.RA
R-011	Regulatory and contractual non-compliance in AI use	All	3	4	12	High	Govern	GV.OC, GV.PO
R-012	Absence of AI-specific incident response procedures	All	3	3	9	Moderate	Manage	RS.MA, RS.CO, DE.AE

L = Likelihood, I = Impact. R-009 to R-012 were added after a gap review of the initial eight risks.

Risk descriptions

- **R-001: Sensitive information exposure through AI tools.** Employees may enter confidential company information, customer data or unreleased product information into unapproved AI tools, causing unauthorised disclosure, privacy violations or loss of competitive advantage.

- **R-002: Inaccurate or misleading AI-generated content.** AI tools may generate false statistics, inaccurate product claims or misleading information. If published without verification, this could cause reputational damage, customer complaints or legal exposure.
- **R-003: Copyright and intellectual property infringement.** AI-generated text, images or code may raise copyright, licensing or ownership concerns.
- **R-004: Unauthorised or unapproved AI tool usage.** Employees may adopt AI tools without IT or Security approval, creating visibility gaps over how company information is processed and stored.
- **R-005: Overreliance on AI outputs without human verification.** Employees may rely on AI recommendations, summaries or decisions without sufficient review, leading to poor decisions or inappropriate actions.
- **R-006: Exposure of customer information through AI integrations.** Support staff may submit identifiable customer information, support conversations or account details to AI tools without safeguards.
- **R-007: Insecure AI-generated code entering production.** Developers may introduce AI-generated code containing vulnerabilities, insecure dependencies or unsafe practices into production systems.
- **R-008: Third-party AI provider security and privacy weaknesses.** The organisation may rely on AI providers without assessing their security practices, data handling, access controls or incident response.
- **R-009: Prompt injection and data leakage through AI integrations.** AI tools connected to internal systems, documents or email may be manipulated by malicious content (indirect prompt injection) into exposing data or taking unintended actions.
- **R-010: Bias and discrimination in AI-assisted HR activities.** AI-assisted job descriptions, screening or candidate summaries may reflect or amplify bias, creating discrimination, fairness and reputational concerns.
- **R-011: Regulatory and contractual non-compliance in AI use.** AI use may conflict with privacy obligations, customer contracts, sector requirements or emerging AI-related laws (for example state-level rules on AI in hiring, or EU requirements if European customers are served).
- **R-012: Absence of AI-specific incident response procedures.** The organisation may be unable to recognise, escalate and contain AI-related incidents such as data pasted into a public tool, harmful outputs or a compromised AI integration.

6. Detailed Risk Assessment and Treatment

All risks use the treatment strategy Mitigate. Target dates are counted from programme start.

R-001: Sensitive information exposure through AI tools

Risk statement: Employees in any department may enter confidential company information or customer data into unapproved AI tools, resulting in unauthorised disclosure, privacy violations or loss of competitive advantage.

Potential causes: No acceptable-use policy; no approved tools list; insufficient data-handling guidance; no confirmed technical safeguards against sensitive data entering public AI tools.

Potential business impact: Exposure of confidential information; unauthorised disclosure of personal information; contractual or regulatory consequences; reduced customer trust.

Inherent rating: Likelihood 4, Impact 4, Score 16, High

Recommended action	Owner	Target
Develop an AI acceptable-use policy	IT/Security	30 days
Establish a register of approved AI tools	IT/Security	30 days
Train employees on safe AI usage	HR and IT/Security	60 days
Evaluate data loss prevention and access restrictions	IT/Security	60 days

Success measure: Register established; policy published; training completed; technical safeguards evaluated and implemented where necessary.

R-002: Inaccurate or misleading AI-generated content

Risk statement: Marketing and support employees may publish or send inaccurate AI-generated statistics, product claims or other misleading content without verification.

Potential causes: No review requirement for external content; time pressure; trust in fluent but unverified outputs; no approved claims reference.

Potential business impact: Reputational damage; customer complaints; false-advertising or contractual exposure.

Inherent rating: Likelihood 4, Impact 4, Score 16, High

Recommended action	Owner	Target
Introduce mandatory human review before external publication	Marketing	30 days
Require verification of statistics and product claims	Marketing	30 days
Establish an approved product claims and messaging reference	Marketing	60 days
Document content approval responsibilities	Marketing	60 days

Success measure: All externally published AI-assisted content undergoes documented human review, with factual claims traceable to reliable sources.

R-003: Copyright and intellectual property infringement

Risk statement: Employees may use AI-generated text, images or code without considering copyright, licensing or ownership implications.

Potential causes: No IP guidance for AI content; unclear licensing terms of AI tools; no review of AI-generated code for licence conflicts.

Potential business impact: IP disputes; takedown demands; uncertainty over ownership of company assets; contractual exposure to customers.

Inherent rating: Likelihood 3, Impact 4, Score 12, High

Recommended action	Owner	Target
Publish guidelines on AI-generated content and IP	Legal	45 days
Require review of externally published AI-generated material	Marketing	30 days
Review licensing and output-ownership terms of approved AI tools	Legal, IT/Security	60 days
Include IP considerations in employee training	HR, Legal	60 days

Success measure: IP guidelines published; approved tools have documented licensing review; training covers IP.

R-004: Unauthorised or unapproved AI tool usage

Risk statement: Employees may independently adopt AI applications without approval, creating security and data governance blind spots.

Potential causes: No approval process; easy access to free AI tools and browser extensions; no monitoring of AI tool usage.

Potential business impact: Unknown data flows; inability to assess provider security; inconsistent controls; difficulty responding to incidents.

Inherent rating: Likelihood 4, Impact 4, Score 16, High

Recommended action	Owner	Target
Create an AI tool request and approval process	IT/Security	30 days
Maintain an approved AI tools register	IT/Security	30 days
Assess tools before adoption	IT/Security	45 days
Periodically review usage (for example network or browser logs) to find unapproved tools	IT/Security	90 days

Success measure: All in-use AI tools are either approved and registered or retired; a repeatable approval process exists.

R-005: Overreliance on AI outputs without human verification

Risk statement: Employees may make business decisions or take operational actions based on AI outputs without sufficient human verification.

Potential causes: No defined review requirements; limited understanding of AI limitations; productivity pressure.

Potential business impact: Inaccurate decisions; inappropriate customer or employee actions; unclear accountability.

Inherent rating: Likelihood 3, Impact 4, Score 12, High

Recommended action	Owner	Target
Define tasks that require mandatory human review	Department Heads	30 days
Assign accountability for decisions involving AI recommendations	Department Heads	45 days
Train employees on AI limitations	HR, IT/Security	60 days
Prohibit fully automated high-impact decisions without governance approval	Executive Leadership	30 days

Success measure: Review requirements documented per department; no high-impact automated decisions without recorded approval.

R-006: Exposure of customer information through AI integrations

Risk statement: Customer support employees may submit personal or confidential customer information to AI tools without authorisation or safeguards.

Potential causes: Support tickets contain identifiable data; AI summarisation is convenient; no masking tools; unclear provider retention practices.

Potential business impact: Privacy breach; contractual breach with business customers; regulatory consequences; loss of customers. Impact is rated 5 because a SaaS company's customers entrust it with their own data.

Inherent rating: Likelihood 3, Impact 5, Score 15, High

Recommended action	Owner	Target
Define approved methods for AI use in customer support	Customer Support, IT/Security	30 days
Prohibit unnecessary submission of identifiable customer data	Privacy/Legal	30 days
Evaluate data masking and anonymisation controls	IT/Security	60 days
Review AI provider data handling and retention terms	Privacy/Legal	60 days

Success measure: Support workflows use approved tools only; identifiable data is masked or excluded; provider retention terms reviewed.

R-007: Insecure AI-generated code entering production

Risk statement: Developers may use AI-generated code containing vulnerabilities or insecure practices, introducing weaknesses into production applications.

Potential causes: AI suggestions accepted without scrutiny; outdated or vulnerable dependencies suggested; no AI-specific secure coding guidance. The scenario assumes general peer review exists, so likelihood is rated possible.

Potential business impact: Exploitable vulnerabilities; customer data compromise; remediation cost; reputational harm. Impact is rated 5 because production flaws in SaaS products can affect all customers.

Inherent rating: Likelihood 3, Impact 5, Score 15, High

Recommended action	Owner	Target
Require code review before merging AI-generated code	Engineering	30 days
Run static application security testing in the pipeline	Application Security	60 days
Add dependency and vulnerability checks	Engineering	60 days
Train developers on secure AI-assisted coding	Application Security	60 days

Success measure: All AI-assisted code passes review and automated scanning before merge; training completed by developers.

R-008: Third-party AI provider security and privacy weaknesses

Risk statement: The organisation may expose data or systems to security and privacy risks by adopting AI providers without sufficient due diligence.

Potential causes: No AI-specific vendor assessment; unclear data retention or model-training practices; weak contractual protections.

Potential business impact: Provider breach affecting company data; hidden use of company data for model training; contractual gaps.

Inherent rating: Likelihood 3, Impact 4, Score 12, High

Recommended action	Owner	Target
Conduct security assessments of AI providers	IT/Security	60 days
Review provider privacy, retention and training-data practices	Privacy/Legal	60 days
Evaluate access controls, encryption and incident response arrangements	IT/Security	60 days
Include security and data protection requirements in vendor agreements	Procurement, Legal	90 days

Success measure: Priority AI vendors have documented assessments; contracts include data protection terms.

R-009: Prompt injection and data leakage through AI integrations

Risk statement: AI tools connected to internal systems, documents, tickets or email may process malicious content that manipulates them into revealing data or taking unintended actions.

Potential causes: AI assistants granted broad access; untrusted content (customer messages, web pages, documents) processed as instructions; no testing of AI integrations.

Potential business impact: Unauthorised data disclosure; unintended actions in connected systems; difficulty detecting misuse.

Inherent rating: Likelihood 3, Impact 4, Score 12, High

Recommended action	Owner	Target
Apply least-privilege access to AI integrations	IT/Security	60 days
Require security review before connecting AI tools to internal systems	IT/Security	45 days
Test priority integrations for prompt injection scenarios	Application Security	90 days
Log and monitor AI integration activity	IT/Security	90 days

Success measure: AI integrations are inventoried, scoped to least privilege and reviewed before connection.

R-010: Bias and discrimination in AI-assisted HR activities

Risk statement: AI-assisted job descriptions, candidate screening or summaries may reflect or amplify bias, creating fairness, legal and reputational concerns.

Potential causes: No review of AI-assisted recruitment; opaque model behaviour; lack of documented human decision points.

Potential business impact: Discrimination complaints; legal exposure; loss of candidate trust; reputational damage.

Inherent rating: Likelihood 3, Impact 4, Score 12, High

Recommended action	Owner	Target
Require human decision-making for all hiring outcomes	HR	30 days
Review AI-assisted job descriptions for biased language	HR	45 days
Document permitted and prohibited AI uses in recruitment	HR, Legal	45 days
Assess applicable hiring and AI-related laws	Legal	60 days

Success measure: No AI tool makes or ranks hiring decisions without documented human review; permitted uses documented.

R-011: Regulatory and contractual non-compliance in AI use

Risk statement: AI use may conflict with privacy obligations, customer contracts, sector requirements or emerging AI-related laws.

Potential causes: No mapping of legal and contractual obligations to AI use; rapidly changing regulation; no designated owner for AI compliance.

Potential business impact: Regulatory scrutiny; contractual breach; customer audit findings; fines or lost deals.

Inherent rating: Likelihood 3, Impact 4, Score 12, High

Recommended action	Owner	Target
Review customer contracts and privacy commitments for AI-related obligations	Legal	60 days
Maintain a register of applicable AI and privacy requirements	Legal, Privacy	90 days
Assign an AI governance lead responsible for regulatory monitoring	Executive Leadership	30 days
Review AI use cases against identified requirements	Privacy/Legal	90 days

Success measure: Applicable requirements documented; each AI use case reviewed against them.

R-012: Absence of AI-specific incident response procedures

Risk statement: The organisation may be unable to recognise, escalate and contain AI-related incidents.

Potential causes: Existing incident response does not mention AI; no reporting route for AI misuse; no playbooks.

Potential business impact: Delayed containment; unreported data exposure; inconsistent response.

Inherent rating: Likelihood 3, Impact 3, Score 9, Moderate

Recommended action	Owner	Target
Add AI incident scenarios to the incident response plan	IT/Security	60 days
Create a simple reporting channel for suspected AI misuse	IT/Security	30 days
Run a tabletop exercise on an AI data exposure scenario	IT/Security	90 days

Success measure: AI incident scenarios documented; tabletop exercise completed and lessons recorded.

7. AI Acceptable-Use Policy: Recommended Key Requirements

The organisation should introduce a formal AI acceptable-use policy with at least the following requirements.

1. **Approved tools.** Employees may only use AI tools approved by the organisation for business purposes.
2. **Data protection.** Employees must not submit confidential company information, personal data, customer records, credentials or sensitive business information to public or unapproved AI tools.
3. **Human oversight.** AI-generated outputs must be reviewed by an employee before being used for important decisions or published externally.
4. **Accuracy and verification.** Employees must independently verify facts, statistics, product claims and other important information generated by AI.
5. **Intellectual property.** Employees must consider copyright, licensing and IP requirements when using AI-generated content or code.
6. **Accountability.** Employees remain responsible for the accuracy, appropriateness and security of work produced with AI assistance.
7. **High-impact decisions.** AI must not make or finalise hiring, disciplinary or other high-impact decisions without documented human review.
8. **Integrations.** AI tools must not be connected to internal systems without security approval.
9. **Reporting.** Employees must report suspected data exposure, unauthorised AI use or other AI-related incidents through established channels.

8. Recommended AI Governance Structure

AI governance should involve business leadership and operational teams, not only IT.

Role	Responsibility
Executive Leadership	Approves AI governance direction and provides oversight
AI Governance Lead	Coordinates the programme and reports significant risks to leadership
IT/Security	Evaluates AI tools, manages security controls and monitors risks
Legal/Privacy	Reviews legal, privacy and contractual implications
HR	Coordinates awareness and training; oversees fair use in recruitment
Department Heads	Ensure responsible AI use within their teams
Employees	Follow AI policies and report potential issues

9. 90-Day AI Governance Roadmap

Timeline	Key activities	Expected outcome
Days 1-30	Appoint AI governance lead; publish acceptable-use policy; create approved tools register; introduce human review requirements; set up AI misuse reporting channel	Basic governance and accountability established
Days 31-60	Deliver employee training; assess data protection controls; review priority AI vendors; introduce content verification; add SAST and dependency checks; add AI scenarios to incident response	Improved awareness and control coverage
Days 61-90	Review implementation evidence; test selected controls and AI integrations; run tabletop exercise; reassess priority risks; update the risk register	Visibility into control effectiveness and residual risk

Proposed key performance indicators

- 100% of departments have documented AI use cases by day 30.
- Approved AI tools register established by day 30.
- Acceptable-use policy published and communicated by day 30.
- At least 95% of employees complete AI security awareness training by day 60, with the remainder completing by day 90.
- All externally published AI-assisted marketing content follows the review process.
- Priority AI vendors have documented security and privacy assessments by day 90.
- All High risks have assigned owners and documented treatment plans by day 30.

These are proposed targets, not actual results.

10. Residual Risk Assessment

Residual risk is the risk remaining after recommended controls are implemented and their effectiveness is assessed.

Illustrative residual risk summary

ID	Risk	Inherent	Rating	Residual	Rating	Basis for change
R-001	Sensitive information exposure through AI tools	4 x 4 = 16	High	2 x 4 = 8	Moderate	Approved tools, training and safeguards reduce likelihood
R-002	Inaccurate or misleading AI-generated content	4 x 4 = 16	High	2 x 4 = 8	Moderate	Mandatory review lowers likelihood; reputational impact remains
R-003	Copyright and intellectual property infringement	3 x 4 = 12	High	2 x 4 = 8	Moderate	Guidelines and licence review reduce likelihood
R-004	Unauthorised or unapproved AI tool usage	4 x 4 = 16	High	2 x 4 = 8	Moderate	Approval process and usage reviews reduce likelihood
R-005	Overreliance on AI outputs without human verification	3 x 4 = 12	High	2 x 3 = 6	Moderate	Review requirements lower likelihood and limit impact
R-006	Exposure of customer information through AI integrations	3 x 5 = 15	High	2 x 5 = 10	High	Likelihood falls, but severity keeps this risk High
R-007	Insecure AI-generated code entering production	3 x 5 = 15	High	2 x 4 = 8	Moderate	SAST and review catch most flaws before production
R-008	Third-party AI provider security and privacy weaknesses	3 x 4 = 12	High	2 x 4 = 8	Moderate	Due diligence and contract terms reduce likelihood
R-009	Prompt injection and data leakage through AI integrations	3 x 4 = 12	High	2 x 3 = 6	Moderate	Least privilege and testing lower likelihood and blast radius
R-010	Bias and discrimination in AI-assisted HR activities	3 x 4 = 12	High	2 x 4 = 8	Moderate	Human decision requirements reduce likelihood
R-011	Regulatory and contractual non-compliance in AI use	3 x 4 = 12	High	2 x 4 = 8	Moderate	Requirements register and review reduce likelihood
R-012	Absence of AI-specific incident response procedures	3 x 3 = 9	Moderate	2 x 2 = 4	Low	Playbooks and exercises improve readiness

Risk acceptance and ownership

ID	Proposed risk owner	Proposed decision
R-006	Privacy/Legal with Executive Leadership	Continue monitoring; consider additional controls such as stricter masking or in-house tooling
All others	Respective owner named in the detailed treatment plans	Accept residual risk at Moderate or Low, subject to annual review

Residual scores are hypothetical targets. They should be recorded as actual reassessments only after implementation evidence and control effectiveness testing are available.

11. Conclusion

Generative AI adoption creates opportunities for productivity and innovation, but organisations must ensure it does not introduce unmanaged security, privacy and operational risks. This assessment shows the importance of establishing governance before AI adoption becomes widespread.

The organisation should prioritise an acceptable-use policy, approved AI tools, employee awareness, human oversight and appropriate technical safeguards. AI governance should remain an ongoing process: as tools, business use cases and threats evolve, the organisation should regularly review its AI inventory, reassess risks and test the effectiveness of its controls.

The goal is not to prevent employees from using AI. It is to enable responsible adoption while protecting the organisation, its employees and its customers.

12. Limitations

This project is a simulated assessment. It is not based on interviews, internal documentation, technical testing or verified evidence from a real organisation. Risk ratings are illustrative and should not be read as universal scores. Framework mappings are illustrative and do not represent formal compliance. The recommended controls require further assessment to determine suitability, feasibility and effectiveness in a real environment. References to laws and regulations are indicative only and are not legal advice.

13. References

- NIST, Artificial Intelligence Risk Management Framework (AI RMF 1.0): https://www.nist.gov/itl/ai-risk-management-framework
- NIST, AI RMF Playbook: https://airc.nist.gov/AI_RMF_Knowledge_Base/Playbook
- NIST, Cybersecurity Framework 2.0: https://www.nist.gov/cyberframework